

[doc. web n. 9994882]
Provision of February 8, 2024
Register of provisions
n. 63 of February 8, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN THE meeting held today, attended by
Prof. Pasquale Stanzione, Prof. Ginevra
Cerrina Feroni, Vice President, Dr. Agostino
Ghiglia, and Attorney Guido Scorza, members, and Dr.
Claudio Filippi, Deputy Secretary General;

HAVING REGARD to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD to Legislative Decree No. 196 of June 30, 2003, containing the "Code regarding the protection of personal data, containing provisions for the adaptation of the national legal system to Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC" (hereinafter "Code");

HAVING REGARD to Legislative Decree No. 101 of August 10, 2018, containing "Provisions for the adaptation of national legislation to the provisions of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, concerning the protection of natural persons with regard to the processing of personal data, as well as the free movement of such data and repealing Directive 95/46/EC";

HAVING REGARD to Regulation No. 1/2019 concerning internal procedures of external relevance, aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor for the protection of personal data, approved by resolution No. 98 of April 4, 2019, published in G.U. No. 106 of May 8, 2019 and in www.gpdp.it, doc. web n. 9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD to the documentation on file;

HAVING REGARD to the observations made by the Deputy Secretary General pursuant to Article 15 of Guarantor Regulation No. 1/2000 on the organization and functioning of the office of the Guarantor for the protection of personal data, doc. web n. 1098801;

Report by Prof. Ginevra Cerrina Feroni;

PREMISED

1. The complaint

By note dated XX, Ms. XX submitted a complaint regarding the transmission, by the Local Health Authority No. 1 of Sassari, on date XX ("15:39PM"), of an email addressed to the aforementioned complainant, but to an email address not belonging to her. In particular, the cited email contained the provision (protocol note n. XX) with which the Extra-Regional Admissions Office, District of Sassari of the Authority, denied the granting of economic benefits, such as travel and accommodation expenses, to access healthcare services under L. R. No. 26/1991 at a private healthcare facility outside the region. According to the statements and documentation provided by the complainant, the aforementioned document contained her identifying data, the indication of the Hospital Authority where she intended to receive healthcare, as well as some elements related to the medical path undertaken and to be undertaken.

By note dated XX (prot. n. XX), the Authority requested the Company, pursuant to Article 157 of the Code, for information useful for the evaluation of the case, sending this request to the address: XX, which appears to have been delivered.

In response to this request for information, however, no feedback was received. Therefore, the Office, by note dated XX (prot. n. XX), having not received compliance from the Company with the request to provide the elements requested by the Guarantor, notified the same Company of the violation of Article 157 of the Code, communicating, pursuant to Article 166, paragraph 5, of the Code, the initiation of proceedings for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation. Along with the aforementioned note of XX, the request sent with the previous note of XX was again transmitted.

By note dated XX, the Company provided feedback to the request for information of XX (subsequently retransmitted with note of XX), forwarding a note from the Management of the District of Sassari, Anglona, Romangia, and Western Nurra, in which it was stated that:

- "on date XX, Ms. (...) Administrative Professional Collaborator of the Extra-Regional Admissions Office of the District of Sassari, sent note XX both to Ms. XX's email (...) and via registered mail of XX, which was collected by her on date XX";
- "it should be noted that due to a mere clerical error, Ms. (...), on date XX, transmitted to Mr. (...), instead of the feedback regarding her own practice, note XX of XX, addressed to Ms. XX. On the same day, having acknowledged the above, being in good faith and unaware of infringing another's rights, she correctly and promptly communicated to Mr. (...) at 16:57 on XX, the erroneous sending of the attachment, and consequently invited him to delete the documentation received concerning another user, as it was a strictly personal document, as proven and documented by the email of XX which is attached to the records";
- "the Writing District apologizes for the inconvenience caused to Ms. XX, and will ensure that similar cases do not occur in the future."

The Company has not provided any argument regarding the lack of response to the request for information made by the Authority, pursuant to Article 157 of the Code, with the note of XX.

2. Assessments of the Department on the processing carried out and notification of the violation referred to in Article 166, paragraph 5 of the Code

In relation to the facts described above, the Office, with note of XX (prot. n. XX) notified the local socio-healthcare company no. 1 of Sassari, pursuant to Article 166, paragraph 5, of the Code, of the initiation of the procedure for the adoption of the measures referred to in Article 58, paragraph 2, of the Regulation, inviting it to submit defensive writings or documents to the Guarantor or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981).

In particular, the Office, in the aforementioned act, represented that, based on the elements in the records, it had emerged that the Company, by transmitting documentation containing health data of Ms. XX to a third party not authorized to receive it, had carried out processing of health data in violation of the basic principles of processing referred to in Articles 5 and 9 of the Regulation, as well as the security obligations referred to in Article 32 of the same Regulation.

With note of XX, the Company submitted its defensive memoranda, in which it particularly highlighted that:

- "in addition to what has already been communicated with note Pec of XX, the nature of the violation in question is exclusively negligent, as the subject did not intend for the event to occur. In fact, the employee of the Extra-Regional Admissions Office promptly invited the sole recipient of the letter to delete the documentation received concerning another user, as it was a strictly personal document, as proven and documented by the email of XX, attached with the aforementioned Pec. Furthermore, it is highlighted that there is no evidence that the user to whom the documentation was erroneously sent actually viewed it";
- "the Company, through the Sassari Social Health District, in order to mitigate the effects of the violation, has implemented internal technical and organizational measures, such as informing the Administrative Offices of the district that handle sensitive data (...). It has also consulted the company's information services, which suggested a system for sending communications via email,

using a password-protected encrypted mail system that the concerned Extra-Regional Admissions Office is already using.”

3. Outcome of the investigative activity

Taking note of what was represented by the Company in the documentation on record, in the defensive memoranda and in the hearing, the following observations are made:

1. “within the powers referred to in Article 58 of the Regulation, and for the performance of its duties, the Guarantor may request the data controller, the processor, the representative of the controller or the processor, the data subject, or even third parties to provide information and to exhibit documents also with reference to the content of databases” (Article 157 of the Code);
2. “health-related data” refers to personal data concerning the physical or mental health of a natural person, including the provision of health care services, which reveal information related to their health status (Article 4, paragraph 1, no. 15, of the Regulation). Recital no. 35 of the Regulation further specifies that health-related data “includes information about the natural person collected during their registration to receive health care services”;
3. the regulation on the protection of personal data provides – in the health sector – that information about health status can be communicated to third parties based on an appropriate legal basis or at the request of the data subject, with prior written authorization from the latter (Article 9 of the Regulation and Article 84 of the Code in conjunction with Article 22, paragraph 11, Legislative Decree No. 101 of August 10, 2018);
4. the data controller is required to comply with the principles regarding data protection, among which is the principle of “integrity and confidentiality,” according to which personal data must be “processed in a manner that ensures adequate security (...), including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage” (Article 5, paragraph 1, letter f) of the Regulation). The adequacy of such measures must be assessed by the data controller in relation to the nature of the data, the object, the purposes of the processing, and the risk to the rights and freedoms of the data subjects, taking into account the risks arising from the destruction, loss, alteration, unauthorized disclosure, or access to personal data transmitted, stored, or otherwise processed (Article 32, paragraphs 1 and 2 of the Regulation);
5. the Company failed to respond to the Authority's request for information of XX and communicated health-related data of Ms. XX that contradicts the basic principles of processing referred to in Articles 5 and 9 of the Regulation as well as the security obligations referred to in Article 32 of the Regulation.

4. Conclusions

In light of the assessments mentioned above, taking into account the statements made by the data controller during the investigation – and considering that, unless the act constitutes a more serious crime, anyone who, in a proceeding before the Guarantor, falsely declares or certifies news or circumstances or produces false acts or documents is liable to...

****Response pursuant to Article 168 of the Code “Falsehoods in declarations to the Guarantor and interruption of the execution of the tasks or the exercise of the powers of the Guarantor”**** - it is represented that the elements provided by the Company in the defensive memoranda do not allow for overcoming the objections notified by the Office with the aforementioned initiation act of the procedure, nor do any of the cases provided for by Article 11 of the Guarantor's Regulation No. 1/2019 apply.

For these reasons, the illegality of the processing of personal data carried out by the local health authority no. 1 of Sassari is noted, in the terms set out in the motivation, in particular, for having processed personal data in violation of the basic principles of processing as per Articles 5 and 9 of the Regulation, the obligations regarding security as per Article 32 of the Regulation, as well as Article 157 of the Code.

In this context, considering that the conduct has exhausted its effects, the prerequisites for the adoption of corrective measures pursuant to Article 58, paragraph 2, of the Regulation do not currently exist.

****5. Adoption of the injunction order for the application of the administrative pecuniary sanction and**

accessory sanctions (Articles 58, paragraph 2, letter i) and 83 of the Regulation; Article 166, paragraph 7, of the Code).**

The violation of Articles 5, 9, and 32 of the Regulation as well as Article 157 of the Code is subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraphs 4 and 5, of the Regulation (cf. Article 166, paragraph 2).

Given that the violation of Articles 5, 9, and 32 of the Regulation and Article 157 of the Code occurred as a result of a single conduct, Article 83, paragraph 3, of the Regulation applies, according to which the total amount of the administrative pecuniary sanction does not exceed the amount specified for the most serious violation. In the case at hand, the most serious violation concerns Articles 5, paragraph 1, letter f), and 9 of the Regulation and Article 157 of the Code, subject to the administrative sanction provided for by Article 83, paragraph 5, of the Regulation.

It should be noted that the Guarantor, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to “impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] measures [corrective] provided for in this paragraph, or in lieu of such measures, depending on the circumstances of each individual case” and, in this context, “the Board [of the Guarantor] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Guarantor's website pursuant to Article 166, paragraph 7, of the Code” (Article 16, paragraph 1, of the Guarantor's Regulation No. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, in light of the elements provided in Article 83, paragraph 2, of the Regulation.

In light of the above and, in particular, of the category of personal data involved in the violation, but also of the small number of subjects involved (one) and the unintentional nature of the violation, it is believed that the level of severity of the violation committed by the Company is low (cf. European Data Protection Board, “Guidelines 04/2022 on the calculation of administrative fines under the GDPR” of May 23, 2023, point 60).

It is also represented that the Company has already been the recipient of a measure adopted pursuant to Article 58 of the Regulation for having carried out a processing of personal data, in a similar circumstance, in violation of the basic principles of processing as per Articles 5 and 9 of the Regulation, and the obligations under Article 32 of the Regulation (provision of March 23, 2023, web doc. no. 9872621).

However, the aforementioned violation cannot be classified as a “previous violation” pursuant to Article 83, paragraph 2, letter e), since the measure that established it was adopted after the conduct that gave rise to the current complaint.

That said, considering a series of elements as a whole and, in particular, that:

- the Authority became aware of the event following a complaint from the data subject (Article 83, paragraph 2, letter h) of the Regulation);
- the data controller, in order to avoid the recurrence of the event, has introduced a password-protected encrypted email system and has requested the recipient of the email to delete the received documentation (Article 83, paragraph 2, letters f) and c) of the Regulation);
- the violation concerned a specific internal structure of the data controller and not the overall organization of the same (Article 83, paragraph 2, letter k) of the Regulation);

it is deemed appropriate to determine the amount of the pecuniary sanction provided for by Article 83, paragraph 5 of the Regulation, in the amount of €18,000.00 (eighteen thousand) for the violation of Articles 5, 9, and 32 of the Regulation and Article 157 of the Code, as an administrative pecuniary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and deterrent.

It is also believed that the accessory sanction of publication on the Guarantor's website of this provision, provided for by Article 166, paragraph 7 of the Code and Article 16 of the Guarantor's Regulation No. 1/2019, should be applied, also considering the type of personal data subject to unlawful processing.

It is finally noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Guarantor, are met.

ALL OF THE ABOVE, THE GUARANTOR declares the unlawfulness of the processing of personal data carried out by the local health and social services company No. 1 of Sassari, for the violation of Articles 5, 9, and 32 of the Regulation and Article 157 of the Code.

ORDERS pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, the local health and social services company No. 1 of Sassari, with registered office in Sassari, Via Alceo Catalocchino, 9 07100 - C.F./P. IVA 02884000908, to pay the sum of €18,000.00 (eighteen thousand) as an administrative pecuniary sanction for the violation indicated in this provision; it is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by paying, within 30 days, an amount equal to half of the imposed sanction.

ORDERS the aforementioned Company, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €18,000.00 (eighteen thousand) according to the methods indicated in the attachment, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement actions in accordance with Article 27 of Law No. 689/1981.

DISPOSES pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Guarantor's website and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers assigned to the Guarantor, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal to the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, February 8, 2024

THE PRESIDENT
Stanzione

THE REPORTER
Cerrina Feroni

THE DEPUTY SECRETARY GENERAL
Filippi